

COMPANION DIGITAL PACKAGE

Chapter Summary Cards

22 one-page quick-reference cards · One per chapter · Print and keep

Key concepts · Exam traps · Key terms · Case study reference Colour-coded by CIDPro™ objective

Mastering Identity Security for CIDPro™ | Abbas Kudrati | 2026

22
Chapter Cards

5
Key Concepts per Card

1
Exam Trap per Card

5
Colour-Coded Objectives

What Is Identity? Understanding the Big Picture

"The control plane of modern security"

KEY CONCEPTS

- Identity system = identity store + authentication + authorisation + audit
- Authentication answers 'Who are you?' · Authorisation answers 'What can you do?'
- Orphaned accounts: active accounts with no legitimate owner — a major risk
- IGA platforms manage compliance: access reviews, SoD, audit evidence
- Zero Trust: no implicit trust based on network location; verify every request

■ EXAM TRAP

Don't confuse authentication with authorisation — they are always separate. Authentication ≠ Authorisation.

KEY TERMS

Identity · Authentication · Authorisation · IGA · Zero Trust · Least privilege · Orphaned account

CASE STUDY

Identity in a large Indian bank — provisioning at scale

Designing Identity — Choosing the Right Architecture

"Centralised, federated, or decentralised — choose wisely"

KEY CONCEPTS

- Centralised: single authority, full control, single point of failure
- Federated: cross-domain SSO using SAML/OIDC, each org keeps own IdP
- Decentralised (SSI): individual holds own identity via digital wallet
- Hybrid: on-premises + cloud IdP with directory sync (e.g. Entra Connect)
- Identity fabric: unified identity services across hybrid environments

■ EXAM TRAP

Federated ≠ SSO. SSO is the user experience outcome; federation is the architectural mechanism that enables it.

KEY TERMS

Centralised identity · Federation · Decentralised identity · Hybrid · Identity fabric · SSO

CASE STUDY

Government e-services platform in Asia — federated architecture

Workforce, Customer, and Partner Identity — Not One Size Fits All

"Three audiences, three completely different requirements"

KEY CONCEPTS

- Workforce IAM: JML lifecycle, HR-driven, compliance-first
- CIAM: millions of users, self-service, UX-first, privacy-critical
- Partner IAM: B2B federation, trust agreements, least-access principle
- CIAM metrics: conversion rate, login success rate, MFA adoption rate, MAU
- Progressive profiling: collect attributes gradually — not all at registration

■ EXAM TRAP

CIAM is optimised for user experience at scale; workforce IAM is optimised for control and compliance. Never conflate them.

KEY TERMS

Workforce IAM · CIAM · Partner identity · Progressive profiling · Conversion rate · MAU

CASE STUDY

Multinational managing all three identity types simultaneously

Human and Non-Human Identities — Managing Both Worlds

"NHIs are the fastest-growing identity risk"

KEY CONCEPTS

- NHI types: service accounts, API keys, OAuth tokens, managed identities, IoT, AI agents
- NHIs outnumber humans 45:1 in enterprise environments
- Hardcoded credentials in code/config are the #1 NHI risk
- Secrets management: store, rotate, and audit all NHI credentials
- SPIFFE/SPIRE: cryptographic workload identity for cloud-native NHIs

■ EXAM TRAP

NHIs can hold excessive privileges just like humans — they need JIT, least privilege, and rotation too.

KEY TERMS

NHI · Service account · API key · Hardcoded credential · Secrets management · SPIFFE/SPIRE

CASE STUDY

Fintech company's API ecosystem — NHI governance at scale

Privacy, Ethics, and Bias in Identity Systems

"Privacy is a design principle, not a checkbox"

KEY CONCEPTS

- Privacy by Design: embed protections from the outset (GDPR Article 25)
- Data minimisation: collect only what is necessary for the stated purpose
- Consent: freely given, specific, informed, unambiguous — easy to withdraw
- Algorithmic bias: AI identity systems must be audited for differential performance
- Purpose limitation: data may not be used for materially different purposes

■ EXAM TRAP

Privacy by Design ≠ Privacy by Default. Design = built in from the start. Default = most protective setting applied automatically.

KEY TERMS

Privacy by Design · Data minimisation · Consent · Purpose limitation · Algorithmic bias · GDPR Art. 25

CASE STUDY

Biometric systems and bias in South-East Asia

Identifiers and Usernames — The Foundation of Digital Identity

"An identifier is not a name — it's a handle for a claim"

KEY CONCEPTS

- Persistent identifier: stable across all interactions (e.g. employee ID)
- Pairwise identifier: unique per relationship — different SP sees different ID
- Transient identifier: temporary, session-scoped (e.g. OAuth state parameter)
- Opaque identifier: reveals no information about the subject (random UUID)
- Username limitations: not globally unique, changes, leaks info about the person

■ EXAM TRAP

Identifiers and names are different. An identifier is a technical handle; a name is an attribute. A person can have multiple identifiers.

KEY TERMS

Persistent identifier · Pairwise identifier · Transient identifier · Opaque identifier · Username

CASE STUDY

National ID systems across Asia — identifier design at national scale

The Digital Identity Lifecycle — From Creation to Deletion

"Every identity has a beginning, a middle, and an end"

KEY CONCEPTS

- Joiner: new identity created, access provisioned, credentials issued
- Mover: role change triggers access review, old access removed, new access granted
- Leaver: account disabled, access revoked, credentials invalidated promptly
- Role creep: accumulation of permissions without revocation — IGA's primary problem
- Orphaned account risk peaks at Leaver — automation and certification are critical

■ EXAM TRAP

Role creep is not a configuration setting — it's the result of failing to certify and revoke. JML must be automated to prevent it.

KEY TERMS

Joiner-Mover-Leaver (JML) · Role creep · Provisioning · Deprovisioning · Orphaned account · SCIM

CASE STUDY

Employee onboarding in a large Indian IT company

Identity Proofing and Identity Binding

"A digital identity is only as trustworthy as how it was established"

KEY CONCEPTS

- IAL1: self-asserted only · IAL2: verified remotely or in-person · IAL3: in-person + mandatory biometric
- CSP proofs and issues credentials · Verifier validates · RP consumes result
- IAL, AAL, and FAL are INDEPENDENT — high IAL does not imply high AAL
- Static KBA is insufficient above IAL1 — breach data defeats knowledge questions
- Binding: associating a verified identity with an authenticator for future use

■ EXAM TRAP

IAL3 = in-person ONLY + mandatory biometric. Remote proofing cannot achieve IAL3.

KEY TERMS

IAL · AAL · FAL · CSP · Applicant → Subscriber → Claimant · Binding · KBA · Liveness detection

CASE STUDY

Aadhaar-based digital KYC in Indian banking

Authentication — Proving You Are Who You Say You Are

"Authentication is about evidence — the more independent, the better"

KEY CONCEPTS

- Three factors: Know (password) · Have (device/key) · Are (biometric)
- MFA = two+ factors from DIFFERENT categories
- FIDO2 = WebAuthn + CTAP — phishing-resistant, domain-bound authentication
- AAL1 = single factor · AAL2 = two factors + crypto · AAL3 = hardware key
- Passkeys: synced = AAL2 · device-bound = AAL3 (NIST SP 800-63-4, July 2025)

■ EXAM TRAP

MFA fatigue attacks bypass push-based MFA. Number matching is the mitigation, not disabling MFA.

KEY TERMS

Authentication factors · MFA · FIDO2 · Passkey · AAL · SSO · Adaptive authentication · Step-up

CASE STUDY

SSO and MFA rollout in a South-East Asian government agency

Authorisation — Deciding What You Can Do

"Access control is only as good as the model behind it"

KEY CONCEPTS

- RBAC: roles represent job functions; permissions attached to roles
- ABAC: decisions based on user + resource + action + environment attributes
- PBAC: formal policy expressions evaluated by a policy engine
- JIT access: elevated permissions on demand with automatic expiry
- Zero Standing Privileges (ZSP): no elevated permissions at rest — ever

■ EXAM TRAP

Role explosion is a failure of RBAC design — too many roles becomes unmanageable. ABAC solves this with attribute logic.

KEY TERMS

RBAC · ABAC · PBAC · Least privilege · SoD · JIT · ZSP · Standing access · Role creep

CASE STUDY

RBAC to ABAC migration in an Australian hospital network

Access Management — Controlling the Gates

"Provisioning without deprovisioning is how breaches persist"

KEY CONCEPTS

- SCIM: RESTful standard for automated provisioning/deprovisioning across systems
- Session management: creation, duration, timeout, revocation controls
- CAEP: real-time session revocation without waiting for token expiry
- Federation enables cross-domain access; trust must be established formally
- Orphaned accounts: provisioned but never deprovisioned — the leaver failure

■ EXAM TRAP

Session timeout and session revocation are different. Timeout = idle expiry. Revocation = forced termination on a security event.

KEY TERMS

Provisioning · Deprovisioning · SCIM · Session · CAEP · Federation · Orphaned account · WAM

CASE STUDY

Automated provisioning failure at a Malaysian bank

Cryptography for Identity — The Science Behind the Security

"Cryptography is the plumbing — you need to know how it works"

KEY CONCEPTS

- Symmetric: same key for encrypt/decrypt · Asymmetric: public + private key pair
- Digital signatures: private key signs, public key verifies — non-repudiation
- PKI: CA signs certificates binding public keys to verified identities
- Password hashing: bcrypt/PBKDF2 with salt — one-way, never reversible
- TLS 1.2 minimum required; TLS 1.3 preferred for all identity traffic

■ EXAM TRAP

Hashing is one-way — you cannot decrypt a hash. Encryption is two-way — you can decrypt with the right key. Never confuse them.

KEY TERMS

Symmetric · Asymmetric · PKI · Digital signature · TLS · JWT · HSM · Salt · bcrypt · X.509

CASE STUDY

TLS misconfiguration at a South Asian financial portal

Security Threats and Best Practices in Identity

"Attackers don't break in — they log in"

KEY CONCEPTS

- AiTM phishing captures credentials AND session cookies — bypasses TOTP MFA
- Credential stuffing ≠ brute force: one attempt per account, uses breach data
- MFA fatigue: repeated push notifications until approval — mitigate with number matching
- Golden Ticket: KRBTGT hash → forge any Kerberos ticket → unlimited access
- Attack chain: Recon → Initial access → Escalation → Lateral movement → Persistence

■ EXAM TRAP

AiTM attacks are defeated by FIDO2 (phishing-resistant MFA), NOT by TOTP. TOTP codes are captured in real time by AiTM proxies.

KEY TERMS

AiTM · Credential stuffing · MFA fatigue · Pass-the-Hash · Golden Ticket · Lateral movement · Persistence

CASE STUDY

Credential stuffing and the Snowflake breach wave

Threat Modelling for Identity Architectures

"Think like an attacker before attackers do"

KEY CONCEPTS

- STRIDE: Spoofing · Tampering · Repudiation · Info Disclosure · DoS · Elevation
- Data Flow Diagram (DFD): processes, data flows, stores, external entities, trust boundaries
- Trust boundary: every data flow crossing one requires STRIDE analysis
- MITRE ATT&CK;: adversary techniques mapped to identity attack patterns
- Continuous threat modelling: integrate into DevSecOps, not just at project start

■ EXAM TRAP

Repudiation is about plausible deniability due to poor logging — not about denial of service. Don't confuse with DoS.

KEY TERMS

STRIDE · DFD · Trust boundary · MITRE ATT&CK; · DREAD · Proactive security · Shift left

CASE STUDY

STRIDE applied retrospectively to the Sisense breach

Rules and Standards That Relate to Identity

"Every identity system operates inside a regulatory landscape"

KEY CONCEPTS

- GDPR: 6 lawful bases · Data minimisation · Purpose limitation · Right of erasure
- Australian Privacy Act: 13 APPs · Notifiable Data Breaches (NDB) scheme
- HIPAA (US health) · SOX (financial controls) · PCI DSS (card data)
- CCPA/CPRA: California privacy rights including opt-out of sale
- eIDAS 2.0: EU digital identity wallet framework

■ EXAM TRAP

GDPR applies extraterritorially — any organisation processing EU residents' data, regardless of where it is located.

KEY TERMS

GDPR · Lawful basis · APPs · NDB · HIPAA · SOX · PCI DSS · CCPA · eIDAS · Data controller

CASE STUDY

Overlapping frameworks in Asia-Pacific financial services

Compliance Approaches for Identity Systems

"Compliance is a posture, not a point in time"

KEY CONCEPTS

- 4 approaches: Control-based · Risk-based · Policy-based · Continuous compliance
- IGA = the compliance backbone: access reviews, SoD, attestation, evidence
- SOC 2 Type II: design + operating effectiveness over 6+ months (more credible than Type I)
- Rubber-stamping: approving reviews without meaningful review — produces no real compliance
- Continuous compliance: real-time monitoring replaces periodic audit snapshots

■ EXAM TRAP

SOC 2 Type I only proves controls were designed correctly at a point in time. Type II proves they actually operated. Type II is the gold standard.

KEY TERMS

IGA · Access certification · SoD · SOC 2 Type I/II · Attestation · Compliance drift · Residual risk

CASE STUDY

Building a compliance programme from scratch

Core IAM Standards and Standards Bodies

"Standards are the universal language of identity interoperability"

KEY CONCEPTS

- SAML 2.0 (OASIS): XML-based enterprise SSO — IdP issues signed assertions
- OAuth 2.0 (IETF): delegated authorisation. OAuth 2.1 adds PKCE mandatory, removes Implicit
- OIDC (OpenID Foundation): adds ID token to OAuth — enables authentication
- SCIM (IETF): RESTful provisioning protocol — the JML automation standard
- FIDO2 = WebAuthn (W3C) + CTAP (FIDO Alliance) — phishing-resistant auth

■ EXAM TRAP

OAuth 2.0 is an AUTHORISATION framework — it does NOT authenticate users. You need OIDC on top of OAuth to get authentication.

KEY TERMS

SAML 2.0 · OAuth 2.0/2.1 · OIDC · SCIM · FIDO2 · LDAP · CAEP · DPoP · PKCE · Verifiable Credential

CASE STUDY

Open banking and IAM standards in APAC

Customer Service Considerations of Identity Solutions

"Every helpdesk call is a social engineering opportunity"

KEY CONCEPTS

- Account recovery is the highest-risk identity operation in customer service
- Vishing: phone social engineering targeting helpdesks for password resets
- Step-up authentication: verify identity before making any account changes
- Post-change notification: alert all channels when credentials change
- Tiered support model: Tier 1 self-service · Tier 2 agent · Tier 3 specialist

■ EXAM TRAP

Agent impersonation (logging in as the customer) removes the audit trail. Always use purpose-built agent tooling with its own identity.

KEY TERMS

Account recovery · Vishing · Step-up authentication · Post-change notification · Fractured identity · WCAG

CASE STUDY

The super-app that redesigned identity UX

Privilege Management Operations — Securing the Keys to the Kingdom

"Privileged access is the highest-value target in any environment"

KEY CONCEPTS

- PAM pillars: Discovery · Vaulting · JIT · Session recording · Monitoring
- Golden Ticket: KRBTGT hash → forge any Kerberos TGT → unlimited domain access
- Pass-the-Hash: NTLM hash → authenticate without plaintext password
- PAW: dedicated hardened device for privileged admin tasks only — never email
- Vaultless PAM: security at authentication layer; no credential onboarding required

■ EXAM TRAP

Standing privilege is the root cause of most privilege abuse. JIT eliminates it; ZSP is the goal.

KEY TERMS

PAM · Credential vault · JIT · ZSP · PAW · Session recording · KRBTGT · LAPS · Mimikatz · Vaultless PAM

CASE STUDY

KRBTGT compromise recovery — rebuilding trust in the domain

Identity Event Monitoring and Response

"See everything. Miss nothing. Act immediately."

KEY CONCEPTS

- Impossible travel: simultaneous logins from impossible locations — high-confidence ATO signal
- Kerberoasting: request TGS tickets for SPN accounts → crack offline → get password
- ITDR: tooling specifically for identity threats — fills gap between IAM config and runtime behaviour
- SOAR playbooks automate response — dramatically reduce MTTR
- Dwell time: global 2024 median = 10 days from breach to detection

■ EXAM TRAP

SIEM collects and correlates logs. ITDR specifically detects identity threats in real time. They are complementary, not interchangeable.

KEY TERMS

Impossible travel · Kerberoasting · ITDR · SOAR · UEBA · MTTR · Dwell time · Password spray · SIEM

CASE STUDY

The alert nobody acted on — and what it cost

Privacy in Identity Operations

"Privacy is not a feature — it's a fundamental right built into your system"

KEY CONCEPTS

- DPIA: mandatory for high-risk processing under GDPR Article 35
- Right to erasure (GDPR Art. 17): requires data lineage across ALL connected systems
- Special category data (GDPR Art. 9): biometric, health, genetic — heightened protection
- EU AI Act (2024/1689): high-risk AI systems include some identity-related AI
- Data Processing Agreement (DPA): mandatory contract between controller and processor

■ EXAM TRAP

Right to erasure is not absolute — it only applies where no lawful basis for retention exists. Active employees cannot erase their HR records.

KEY TERMS

DPIA · Right to erasure · Special category data · EU AI Act · DPA · Privacy by Default · Biometric data

CASE STUDY

The delete request that took 47 days — what went wrong

Operating Identity Systems at Scale

"Identity is a system — it requires runtime observability like any other"

KEY CONCEPTS

- IVIP: Identity Visibility and Intelligence Platform — runtime observability layer
- IDEAL Framework: Integrate · Discover · Enforce · Act · Lightweight
- APEX model: Assume Compromise · Prioritise Continuously · Eliminate Implicit Trust · eXchange Intelligence · Elevate Offensively
- Identity Firewall: block compromised account from ALL auth during active incident
- ZSP coverage rate: % of privileged identities with no standing elevated permissions

■ EXAM TRAP

Identity at scale requires runtime observability — knowing your policies is not the same as knowing what identities are actually doing.

KEY TERMS

IVIP · IDEAL · APEX · Identity Firewall · Geo-distributed auth · Staged rollout · ZSP coverage rate · Agentic AI

CASE STUDY

The CISO who could not answer the question — and why IVIP solved it